

Security Incident Investigation Report

Ransomware Intrusion & Data Exfiltration Event
OpenSlop, Inc. — Corporate & Production Environments

CONFIDENTIAL — RESTRICTED DISTRIBUTION

INCIDENT ID	IR-2026-0417	SEVERITY	Critical (SEV-1)
PREPARED BY	Cyber Defense & Incident Response Team (CDIR)	STATUS	Closed — Post-Incident
REPORT DATE	17 April 2026	VERSION	1.0 (Final)
CLASSIFICATION	TLP:AMBER+STRICT — Do not distribute outside authorized recipients		

Document Control

VERSION	DATE	AUTHOR	DESCRIPTION
0.1	2026-04-11	J. Okafor (IR Lead)	Initial draft — timeline reconstruction
0.5	2026-04-14	CDIR Team	Technical analysis and forensic findings added
0.9	2026-04-16	M. Alvarez (CISO)	Executive review, impact and recommendations
1.0	2026-04-17	CDIR Team	Final — approved for restricted distribution

Distribution List

NAME / ROLE	ORGANIZATION	NEED-TO-KNOW
M. Alvarez — Chief Information Security Officer	OpenSlop, Inc.	Owner
R. Chen — Chief Technology Officer	OpenSlop, Inc.	Full
Legal & Privacy Counsel	OpenSlop, Inc.	Full
External Counsel / Cyber Insurer	Third Party	Summary + IOCs

Contents

1. Executive Summary	3
2. Incident Overview & Classification	3
3. Incident Timeline	4
4. Technical Analysis of the Attack	4
5. Impact Assessment	6
6. Containment, Eradication & Recovery	7
7. Indicators of Compromise	7
8. Recommendations	8
9. Lessons Learned & Appendix	8

1. Executive Summary

Between **28 March and 09 April 2026**, OpenSlop, Inc. ("OpenSlop") — a mid-sized SaaS provider of content-moderation tooling — experienced a targeted intrusion that culminated in the theft of approximately **1.4 TB** of corporate and customer data and the deployment of ransomware across a significant portion of the Windows server estate. The Cyber Defense & Incident Response (CDIR) team, supported by an external forensics partner, has assessed this as a **Critical (SEV-1)** incident.

The threat actor gained an initial foothold on **28 March** through a targeted email campaign directed at three employees in the Finance department. A malicious document delivered as an email attachment was opened by a user in Accounts Payable, which executed a loader and established a foothold on the workstation **FIN-WS-07**. Over the following eleven days the actor escalated privileges, harvested credentials, moved laterally into the corporate domain and, ultimately, the production hosting environment, staged and exfiltrated data to attacker-controlled cloud infrastructure, and detonated ransomware during the early morning of **09 April**.

The intrusion demonstrated the hallmarks of a financially motivated, human-operated ransomware operation. The actor was deliberate and patient, favored the use of legitimate administrative tooling and stolen credentials over custom malware ("living off the land"), and took active steps to disable security controls and destroy evidence prior to encryption. At this time the activity has not been attributed to a specific named group, though the tradecraft overlaps with several double-extortion affiliates.

Bottom line: The attacker held privileged access to OpenSlop's environment for approximately eleven days before detection. Encryption was contained to roughly 40% of the server estate due to a timely response, but data exfiltration was completed prior to containment and customer notification obligations have been triggered.

2. Incident Overview & Classification

ATTRIBUTE	DETAIL
Incident ID	IR-2026-0417
Incident type	Ransomware with data exfiltration (double extortion)
Severity / Priority	Critical (SEV-1 / P1)
Date of initial compromise	28 March 2026, ~09:42 UTC
Date of detection	09 April 2026, ~03:15 UTC
Date of containment	09 April 2026, ~11:40 UTC
Dwell time	~11 days, 18 hours
Affected systems	~120 Windows hosts (workstations + servers), 2 hypervisors, 1 backup appliance
Data impacted	~1.4 TB staged/exfiltrated; HR, finance, and customer configuration data
Business impact	~54 hours partial service degradation; SLA breaches on two enterprise tenants

The incident was detected when a member of the Security Operations Center (SOC) responded to a burst of alerts indicating mass file modification on a file server, coinciding with the failure of the nightly backup job and multiple endpoint agents reporting offline. Manual triage rapidly confirmed active ransomware deployment, and the incident was escalated to SEV-1 within eighteen minutes of the first confirmed indicator.

3. Incident Timeline

All times are in UTC. The timeline below was reconstructed from EDR telemetry, Windows event logs, VPN and firewall logs, cloud audit trails, and forensic disk analysis of key hosts.

TIMESTAMP	PHASE	EVENT
03-28 09:42	Initial Access	Finance user opens a macro-enabled attachment ("Invoice_Q1_Remittance.xlsx") from a spoofed supplier email on FIN-WS-07 .
03-28 09:43	Execution	Document macro spawns an encoded PowerShell command that retrieves a second-stage loader.
03-28 10:05	Persistence	A Run key and a scheduled task named MicrosoftEdgeUpdateTaskCore are created to survive reboot.
03-29 02:11	Discovery	Automated enumeration of local accounts, domain trusts, and reachable hosts observed.
03-30 14:30	Cred. Access	LSASS process memory accessed on FIN-WS-07 ; cached credentials harvested.
03-31 22:48	Lateral Move	First RDP session from FIN-WS-07 to APP-SRV-02 using stolen finance-admin credentials.
04-02 18:20	Priv. Esc.	Kerberoasting against service accounts; a domain-admin-equivalent account is compromised.
04-04 → 04-07	Collection	Sensitive shares enumerated; data compressed into multi-part archives on FILE-SRV-01 .
04-06 03:00	Exfiltration	~1.4 TB transferred to attacker cloud storage over HTTPS across three nights.
04-08 23:50	Defense Evasion	Endpoint protection disabled on multiple servers; Windows event logs cleared.
04-09 02:40	Impact	Volume shadow copies deleted; backup catalog corrupted; ransomware binary pushed via admin shares.
04-09 03:15	Detection	SOC alerts on mass file modification + agent offline storm; SEV-1 declared.
04-09 11:40	Containment	Affected segments isolated; domain credentials reset; internet egress restricted.

4. Technical Analysis of the Attack

This section describes the adversary's activity in the order it occurred across the intrusion lifecycle. Findings are drawn from forensic artifacts and correlated telemetry.

4.1 Initial Access

The intrusion began with a small, well-crafted email campaign. Three Finance employees received messages impersonating a known OpenSlop supplier, each carrying a macro-enabled spreadsheet designed to look like an outstanding remittance advice. The sender domain was a look-alike of the legitimate supplier and passed basic inspection. One recipient in Accounts Payable opened the attachment and enabled content, at which point the embedded macro executed. Forensic examination of `FIN-WS-07` confirmed the document was the patient-zero artifact; the other two recipients did not enable the macro and their machines showed no follow-on activity.

4.2 Execution & Foothold

Upon the user enabling content, the macro launched a heavily encoded command interpreter session. The script decoded itself in memory and reached out to a staging server to pull down a lightweight loader. Rather than writing an obvious executable to disk, the loader body was retrieved and executed largely in memory, and its on-disk components were obfuscated and base64-encoded to frustrate static inspection. The loader established the actor's command-and-control channel and provided interactive access to the host.

4.3 Persistence

To ensure the foothold survived reboots and user logoffs, the actor established two independent persistence mechanisms on the initial host. First, a registry Run key was written under the current user's hive to relaunch the loader at logon. Second, a scheduled task masquerading as a Microsoft Edge update routine (`MicrosoftEdgeUpdateTaskCore`) was registered to execute the payload on a recurring basis. Later in the intrusion, after obtaining elevated rights, the actor created a new local account on several servers to provide a durable, credentialed backdoor that did not depend on the malware remaining resident.

4.4 Privilege Escalation

Initial access was in the context of a standard user. The actor escalated in two ways. On the initial workstation, exploitation of an unpatched local vulnerability was used to obtain SYSTEM-level rights. More significantly, once domain credentials were harvested, the actor requested service tickets for accounts with service principal names and cracked them offline to recover the plaintext password of a service account that held domain-admin-equivalent privileges. From that point the actor operated primarily by abusing these valid domain accounts rather than exploiting software.

4.5 Defense Evasion

The actor invested considerable effort in avoiding and undermining detection. Payloads were obfuscated and encoded to evade signature-based controls. As privileges allowed, the actor tampered with the registry to weaken host protections and, on multiple servers, disabled or modified the endpoint protection agents outright to prevent detection during the final stages. Immediately before encryption, the actor cleared Windows event logs on several hosts in an attempt to destroy forensic evidence and slow the investigation.

4.6 Credential Access

Credential theft was central to the operation's success. On the initial host, the actor accessed the memory of the LSASS process to extract cached credentials and Kerberos material. The actor also queried credential stores and browser-saved secrets to broaden the set of usable accounts. These harvested credentials — a mix of local administrator and finance-privileged domain accounts — enabled the subsequent lateral movement without further exploitation.

4.7 Discovery

Throughout the intrusion the actor performed systematic reconnaissance of the environment. Shortly after gaining a foothold, automated tooling enumerated local and domain accounts and mapped domain trust relationships. The actor identified other reachable hosts on the network, scanned for listening services to find high-value targets such as file servers and hypervisor management interfaces, and collected system configuration details from compromised machines to inform targeting. This discovery activity directly shaped the choice of lateral movement paths and collection targets.

4.8 Lateral Movement

Armed with stolen credentials, the actor moved through the environment using native remote-access protocols. The first hop was an interactive Remote Desktop session from the initial workstation to an application server. From there, the actor used Windows administrative shares over SMB to access additional servers and to stage tooling. The ransomware and supporting utilities were copied from host to host across these administrative shares as the actor expanded its reach into the file-server tier and, ultimately, the virtualization platform.

4.9 Command & Control

The loader's command-and-control traffic was tunneled over standard web protocols (HTTPS) to blend with normal outbound browsing and evade egress filtering. During the operation the actor pulled additional tools down to compromised hosts as needed. To provide a resilient, hands-on-keyboard channel that would not look anomalous to defenders, the actor also installed a legitimate commercial remote-management/remote-access application on two servers and operated through it.

4.10 Collection & Exfiltration

Prior to encryption, the actor prioritized data theft to enable extortion. Sensitive data was gathered from local drives and network shares — including HR records, finance documentation, and customer configuration exports — and compressed into multi-part, password-protected archives on `FILE-SRV-01` using an archiving utility. Over three consecutive nights the staged archives, totaling roughly 1.4 TB, were transferred out of the environment to attacker-controlled cloud storage over an encrypted web channel, deliberately timed for low-activity windows to avoid notice.

4.11 Impact

The destructive phase was executed in the early hours of 09 April. To cripple recovery, the actor first deleted volume shadow copies and corrupted the backup catalog on the backup appliance, and stopped database and backup-related services to ensure files were unlocked for encryption. The ransomware binary was then distributed to targeted hosts through administrative shares and executed, encrypting data across roughly 40% of the server estate before the response team isolated the affected segments. A ransom note was

written to affected directories demanding payment in exchange for a decryptor and the non-publication of the stolen data.

5. Impact Assessment

5.1 Operational Impact

Encryption affected approximately 120 Windows hosts, including two file servers, the primary and secondary application tiers, and one of two virtualization hosts. Two enterprise customer tenants experienced service outages that breached contractual SLAs. Total measurable service degradation lasted approximately 54 hours, with full restoration of all services achieved over the subsequent nine days.

5.2 Data Impact

DATA CATEGORY	APPROX. VOLUME	SENSITIVITY	NOTIFICATION TRIGGER
HR / employee records (PII)	~40 GB	High	Yes — data protection regulators
Finance & accounting records	~120 GB	High	Yes — contractual
Customer configuration / metadata	~900 GB	Critical	Yes — customer + regulatory
Internal source & build artifacts	~300 GB	Medium	Under review

Confirmation of exfiltration is supported by outbound transfer volumes in firewall and proxy logs that correlate with the staged archive sizes. The affected customer configuration data does not, per current analysis, include plaintext end-user passwords, but does include tenant metadata and integration secrets, which have been rotated.

5.3 Financial & Reputational Impact

Direct costs include incident response, forensics, overtime, and infrastructure rebuild. Indirect exposure includes potential regulatory penalties, SLA credits, and reputational harm. No ransom was paid; recovery was achieved from offline backups that predated the intrusion combined with rebuild of affected systems.

6. Containment, Eradication & Recovery

6.1 Immediate Containment

- Network isolation of affected VLANs and the virtualization host; internet egress restricted to deny the C2 and cloud-exfiltration destinations.
- Forced password reset of all domain accounts and full rotation of Kerberos ticket-granting-ticket keys (krbtgt) — performed twice, 12 hours apart.
- Disablement of the attacker-created local accounts and removal of the malicious scheduled task and Run-key persistence.
- Revocation and reissue of tenant integration secrets and API keys identified in exfiltrated configuration data.

6.2 Eradication

- Rebuild-from-clean of all systems that were encrypted or confirmed to have hosted attacker tooling; no in-place cleaning of compromised servers.
- Removal of the unauthorized remote-management software and blocking of its associated domains at the proxy.
- Patching of the exploited local privilege-escalation vulnerability across the estate.

6.3 Recovery

- Staged restoration from offline backups validated against a known-good baseline before reconnection.
- Heightened monitoring and threat hunting for 30 days post-recovery, with specific detections built for the observed tradecraft.
- Customer and regulator notifications issued in accordance with legal guidance within the applicable statutory windows.

7. Indicators of Compromise

IOCs are provided for detection and blocking. Values are illustrative and sanitized for this report; the machine-readable IOC package (STIX) is distributed separately to authorized recipients.

TYPE	INDICATOR	CONTEXT
Email sender	ap-billing@0penslop-supplier[.]com	Look-alike phishing sender
File (SHA-256)	a1b2...9f3c (Invoice_Q1_Remittance.xlsx)	Malicious macro document
File (SHA-256)	7d4e...21ab (loader.dll)	Second-stage loader
Domain	cdn-update-sync[.]net	C2 / staging over HTTPS
IP address	185.203.XX.XX	C2 endpoint
Cloud endpoint	hxxps://storage-eu-3[.]exfil-host[.]io	Exfiltration destination
Scheduled task	MicrosoftEdgeUpdateTaskCore	Persistence, masquerading
Filename	svc_host32.exe , rclone-x.exe	Staged tooling
Ransom note	RESTORE-YOUR-FILES.txt	Dropped in encrypted directories

8. Recommendations

The following prioritized recommendations address the root causes and the specific weaknesses exploited during this intrusion.

Priority 1 — Immediate (0–30 days)

- **Harden email & macros:** Block macros from the internet by policy; expand attachment sandboxing and impersonation/look-alike-domain protection.
- **Enforce phishing-resistant MFA** on all remote access, privileged accounts, and internet-facing services.
- **Protect credentials:** Enable LSASS protection (PPL / Credential Guard) and remove standing local-admin rights on workstations.
- **Tamper protection:** Enforce EDR tamper protection so agents cannot be disabled by administrators on endpoints.

Priority 2 — Short term (30–90 days)

- **Tier the administrative model** and eliminate service accounts with domain-admin-equivalent rights; adopt group-managed service accounts with long, random passwords to defeat offline ticket cracking.
- **Network segmentation:** Restrict RDP and SMB between workstations and servers; require jump hosts for administrative access.
- **Immutable, offline backups:** Implement air-gapped/immutable backups with tested restore procedures and monitoring for shadow-copy deletion.
- **Egress control:** Default-deny outbound with allow-listing; alert on unsanctioned cloud-storage and remote-management tools.

Priority 3 — Strategic (90+ days)

- Mature detection engineering around living-off-the-land techniques, credential theft, and mass-file-modification behavior.
- Establish a formal privileged-access-management (PAM) solution with session recording and just-in-time elevation.
- Run regular purple-team exercises modeled on the tradecraft observed in this incident.

9. Lessons Learned & Appendix

9.1 What Worked

- SOC triage escalated to SEV-1 within 18 minutes of the first confirmed indicator, limiting encryption to ~40% of the estate.
- Offline backups predating the intrusion enabled recovery without paying a ransom.
- Cross-team coordination (SOC, IT, Legal, Comms) followed the incident-response plan effectively once invoked.

9.2 What Needs Improvement

- Eleven days of undetected dwell time indicates gaps in detection of early-stage discovery, credential theft, and lateral movement.
- Excessive standing privilege (over-permissioned service accounts, broad local-admin) accelerated escalation.
- Backup infrastructure was reachable and modifiable from the production domain, allowing recovery inhibition.

Appendix A — Evidence Sources: EDR telemetry (workstation + server), Windows Security/System/PowerShell event logs, domain controller logs, VPN/firewall/proxy logs, cloud storage audit logs, and forensic disk images of FIN-WS-07 , APP-SRV-02 , and FILE-SRV-01 . Chain of custody maintained for all imaged systems.

Appendix B — Attribution Note: At the time of writing the activity is unattributed. Tradecraft (human-operated, double-extortion, living-off-the-land) overlaps with multiple ransomware affiliates. Attribution is not required for remediation and no high-confidence assessment is asserted.

— End of Report IR-2026-0417 (v1.0) — Prepared by the OpenSlop Cyber Defense & Incident Response Team —
Classification: TLP:AMBER+STRICT —